

The Password Problem

Abdul Rahman Siddiqui Mohammed · 160923733216 · CSE - B2

"A proof of a theorem contains more knowledge than the mere fact that the theorem is true." - Goldwasser, Micali & Rackoff, 1985, the paper that made it possible to prove you know something without ever saying what it is.

Every login box in existence asks you to do the same slightly strange thing: type a secret, and hand it to a stranger's server so they can check it. This report is about why that arrangement has been quietly broken for decades, who has tried to fix it, and why the fix still hasn't reached most of the software anyone actually uses. Twenty papers and standards are examined here, spanning 1975 to 2026, chosen not to tick off a syllabus checklist but because each one adds a piece to a single throughline: authentication is cryptography's most theoretically solved and most practically unsolved problem, all at once.

The Weakest Link

Cryptography has, by most measures, already won. The mathematics behind a modern encrypted connection - factoring large numbers, discrete logarithms on elliptic curves - is not seriously in dispute. What remains genuinely unresolved is the much less glamorous question of how a human, holding nothing but a memorized word, proves who they are to a machine they've never met. Jerome Saltzer and Michael Schroeder laid out the ground rules for this back in 1975, in what is still the field's founding text on protection [1]: least privilege, complete mediation, the idea that a system should assume nothing about a user's honesty and verify everything anyway. Authentication is the practical sharp end of that principle, and it is where theory and reality have diverged most visibly.

The divergence starts with Whitfield Diffie and Martin Hellman's 1976 paper, the one that invented public-key cryptography and solved the problem of exchanging a secret over an open channel [2]. It is a genuinely beautiful piece of mathematics - and it authenticates nobody. Two parties can agree on a shared secret without ever having met, but neither has any way of knowing who they actually just agreed with. That gap, sitting quietly underneath nearly fifty years of security infrastructure, is the starting point for everything else in this report.

A partial answer arrived nine years later, in 1985, when Shafi Goldwasser, Silvio Micali, and Charles Rackoff introduced the zero-knowledge proof: a way to convince someone you know a secret without revealing anything about it at all [3]. It is one of the more elegant ideas in computer science, and for a long time it stayed almost entirely theoretical. The interesting part of this report's story is what happened when people finally tried to apply it to something as mundane as a password box.

When Passwords Get Stolen

It's worth being concrete about what actually goes wrong, because the failures aren't hypothetical. In October 2023, attackers used a technique called credential stuffing - simply trying username-password pairs leaked from unrelated breaches years earlier - to access roughly 5.5 million 23andMe user profiles, even though 23andMe's own systems were never directly compromised [4]. The weak point wasn't a firewall or an encryption algorithm; it was the assumption that a password, once typed correctly, means the right person is typing it.

Password-authenticated key exchange protocols exist precisely to make this kind of attack harder, but they aren't automatically safe either. A 2026 analysis of reverse online guessing attacks against PAKE protocols shows that even purpose-built password-authentication schemes can leak enough information for an attacker to narrow down guesses far faster than a naive brute force would suggest [5] - a useful reminder that "we used a proper protocol" and "we are actually secure" are not the same claim. And underneath both of these sits the oldest attack

of all: simply asking the user for their password directly. Phishing remains the most efficient way to harvest a working credential in the first place, and a 2023 survey proposing a new taxonomy across email, SMS, and web-based phishing makes clear that the sheer variety of delivery mediums has outpaced most single-method defences [6].

The weak point wasn't a firewall or an encryption algorithm; it was the assumption that a password, once typed correctly, means the right person is typing it.

Proving Without Revealing

The formal vocabulary for what a login is actually supposed to guarantee comes from ITU-T's X.800 standard, which defines authentication, non-repudiation, and data integrity as distinct security services, each implementable through specific mechanisms like encipherment or digital signatures [7]. It's a dry document, but it's the reason every textbook and every paper cited here can talk about "authentication mechanisms" as a shared, precise concept rather than a vague gesture.

The mechanisms themselves rest on two 20th-century breakthroughs. Ron Rivest, Adi Shamir, and Leonard Adleman turned Diffie and Hellman's public-key idea into something implementable in 1978, building RSA on the difficulty of factoring large numbers [8] - still, remarkably, in everyday use. Neal Koblitz then showed in 1987 that the same underlying idea could be rebuilt on elliptic curves instead, achieving equivalent security with dramatically shorter keys [9], which is exactly why almost every modern authentication protocol, including the one this report eventually arrives at, is built on elliptic curve math rather than RSA's older approach.

The Building Blocks Underneath

None of this happens in isolation from the more familiar half of a cryptography syllabus. Once a login succeeds, the actual conversation that follows is protected by symmetric encryption, and the choice of cipher still matters. A 2023 comparative study of AES, DES, RSA, and ECC found no universal winner - AES remains fastest for bulk encryption, while ECC wins on memory and key size in constrained settings [10], a genuinely useful finding for anyone tempted to assume one algorithm is simply "better." ChaCha20, the stream cipher increasingly used alongside modern key exchange, was specifically designed to resist the differential and linear cryptanalysis that eventually wears down older ciphers like RC4 [11]. But even ChaCha20 isn't invulnerable in practice: a documented attack against real OpenSSH and OpenSSL implementations showed that cryptographic key material could be pulled directly out of virtual machine memory, sidestepping the cipher's mathematical strength entirely [12] - a small, sobering reminder that the session key established right after a successful login is only as safe as the memory it sits in afterward.

Closing the Gap

This is the part of the literature where theory finally starts catching up to the problem posed in the opening section. In 2018, Stanislaw Jarecki, Hugo Krawczyk, and Jiayu Xu published OPAQUE, an asymmetric password-authenticated key exchange protocol with a genuinely striking property: the server never sees, stores, or even briefly reconstructs the user's actual password, not even during the very first signup [13]. If the server's entire database is stolen, there is nothing in it that lets an attacker recover a real password through offline guessing - the exact gap left open by Diffie-Hellman forty-two years earlier finally gets a rigorous, provable answer. It took until July 2025 for OPAQUE to be finalized as an IETF standard (RFC 9807), which says something on its own about how long it takes secure theory to become deployable practice.

A cryptographically airtight login is not, on its own, the whole story, and recent work increasingly treats it as only half the picture. A 2025 conference paper proposes wrapping authentication in an adaptive risk engine that continuously reads device, environmental, and behavioural signals and assigns a live trust score, deciding in real

time whether to let a session through, challenge it further, or block it outright [14]. Idris Sarker's 2022 ACM Computing Surveys review of machine-learning-based behavioural authentication makes the underlying case for why this matters: typing rhythm, navigation habits, and device fingerprints carry real signal about whether the person behind a valid password is actually who they claim to be [15]. A 2025 preprint on real-time, AI-driven risk-based access decisions pushes this further still, describing systems that combine Zero Trust principles with behavioural analytics to make per-session access calls rather than a single static gate at login [16]. Put together, these three papers describe a fairly clear emerging shape: a strong cryptographic proof of identity, plus a continuously updating layer of behavioural trust sitting on top of it.

A cryptographically airtight login is not, on its own, the whole story.

Beyond Passwords

Two horizons sit further out. The first is quantum computing, which threatens to make the discrete-logarithm and factoring problems underneath RSA, Diffie-Hellman, and ECC solvable in practical time. A 2025 IEEE review of NIST's finalized post-quantum standards - lattice-based key encapsulation and digital signatures among them - lays out both the software and hardware implementation strategies now needed to migrate [17], while a broader 2023 survey tracks the standardization competition itself and compares finalist algorithms across real hardware [18]. The second horizon is closer and stranger: AI is now being turned directly against cryptography rather than just used to defend it. A 2025 survey on AI applications in cryptanalysis documents how deep learning models are being trained to perform side-channel and differential-fault analysis against ciphers with a level of pattern recognition traditional cryptanalysis couldn't match [19] - raising an uncomfortable question this report returns to below: what happens when that same capability gets pointed at the guessing attacks already documented against PAKE protocols in entry [5]?

Does It Actually Hold Up?

Surveys and protocol papers are one thing; production systems are where the gap between theory and practice actually shows up. A 2021 ACM Computing Surveys case study of real consumer IoT cameras found devices authenticating themselves to the cloud using nothing more than a fixed, easily spoofed MAC address - no cryptographic proof of identity at all, just a static identifier anyone could copy [20]. It is, in miniature, exactly the failure mode this entire report has been building toward: a working cryptographic answer to authentication has existed in the literature since at least 2018, and yet real, shipping devices in 2021 were still using something a determined attacker could defeat with a packet sniffer.

So, What's Actually Missing?

Read together, these twenty sources don't point to a shortage of good cryptography. They point to a lag - a wide, well-documented gap between protocols that are provably secure on paper and systems that actually use them. Diffie-Hellman exposed the key-distribution problem in 1976; a properly hardened, standardized fix for its authentication blind spot didn't arrive until OPAQUE's 2025 finalization, very nearly half a century later. In the meantime, real systems kept shipping with the weakest available option, from fixed MAC addresses in IoT cameras to plain password-over-TLS logins vulnerable to exactly the credential-stuffing and guessing attacks documented in entries [4] and [5].

A second, quieter gap sits in how little the emerging threats are studied together. Post-quantum migration, AI-driven cryptanalysis, and PAKE-specific guessing attacks are each active, well-populated research areas on their own - but almost nothing in the literature surveyed here asks whether an AI-accelerated cryptanalytic technique could make the guessing attacks in entry [5] meaningfully worse, or whether post-quantum key exchange introduces new side channels of its own. And a third gap, more practical than theoretical, is accessibility: OPAQUE is mathematically sound and now formally standardized, but genuinely easy-to-integrate

implementations for ordinary application developers remain scarce, which is arguably the single biggest reason adoption still lags so far behind the protocol's age.

Research Gaps

Pulled out of the discussion above into a direct list, for reference:

Gap 1 - Authentication was left out of the original key-exchange design. Diffie-Hellman (1976) solved key distribution but built in no way to verify who the other party actually is, and this went unaddressed at the protocol level for decades [2].

Gap 2 - A proven fix exists but adoption lags decades behind. OPAQUE (2018) closes the authentication gap with a formal security proof yet only reached IETF standardization in 2025 - and real, easy-to-integrate implementations for ordinary developers remain scarce even now [13].

Gap 3 - Emerging threats are studied in silos, not together. Post-quantum cryptography, AI-driven cryptanalysis, and PAKE-specific guessing attacks each have active research communities, but no source in this review tests them in combination - e.g., whether AI-accelerated cryptanalysis makes PAKE guessing attacks meaningfully worse [5], [17]–[19].

Gap 4 - A cryptographic proof of identity is treated as sufficient on its own, when recent work suggests it shouldn't be. Entries [14]–[16] all point toward continuous, behaviourally-aware risk scoring as a necessary second layer, but this remains a proposal-stage direction rather than something bundled by default with authentication protocols.

Gap 5 - Real deployments consistently lag behind what the literature already recommends. The 2021 IoT case study found production devices authenticating with nothing more than a spoofable fixed identifier [20], years after cryptographically sound alternatives were already published - a pattern that shows up repeatedly across this bibliography, not just in that one case study.

Gap 6 - Session security after authentication is a separate, sometimes-overlooked risk. Even a cryptographically perfect login handshake hands off to a symmetric session key that can still be extracted from memory in practice, as shown for ChaCha20 [12] - a reminder that authentication research and session-security research don't always talk to each other.

Where This Could Go

The most consistent, evidence-backed direction across this bibliography isn't a call for new mathematics - the mathematics already exists and has been proven sound. It's a call for three things happening together, each one closing a specific gap identified above: replacing plain, unauthenticated key exchange with a hardened asymmetric PAKE protocol like OPAQUE as the default rather than the exception; layering a continuously-updating, behaviourally-aware risk engine on top of that cryptographic proof rather than treating a successful login as a one-time, permanent grant of trust; and packaging both of those together as something an ordinary developer could actually drop into an existing login flow without a ground-up rewrite. None of the individual pieces are missing from the research literature. What's missing is the connective tissue between a proof that something can be built securely and a system that actually gets built that way - and closing that particular gap looks like the most promising, and most overdue, direction this field can take next.

The Five Papers That Matter Most

All twenty sources earn their place in this report, but five carry the actual weight of the argument - the ones this project's direction most directly depends on:

1. OPAQUE (Jarecki, Krawczyk & Xu, 2018) [13] - the centrepiece. Every other paper in this shortlist either sets up the problem OPAQUE solves or builds on top of the solution it provides.
2. Reverse Online Guessing Attacks on PAKE Protocols (2026) [5] - the most direct stress-test of OPAQUE's protocol family, and the clearest evidence that "we used a PAKE protocol" still needs to be checked, not assumed, for security.
3. Enhanced MFA Framework Against Modern Security Threats (2025) [14] - the clearest existing blueprint for the adaptive risk-scoring layer meant to sit on top of a cryptographic login.
4. Sarker, Machine Learning for Behavioural User Authentication (2022) [15] - the evidentiary case for why behavioural signals are worth trusting as a second authentication layer in the first place.
5. Real-Time Risk-Based Access Decisions Using AI and Behavioural Analytics (2025) [16] - the most current picture of where risk-based, continuous authentication is actually heading as a field.

Diffie-Hellman [2] and the 23andMe case study [4] were close calls for this list - both are essential to the report's argument, but as scene-setting rather than as sources the eventual solution direction leans on directly.

The One Paper This Report Keeps Coming Back To

If this report had to be built around a single citation, it would be entry [13]: Jarecki, Krawczyk, and Xu's 2018 OPAQUE paper. Every earlier section leads to it, and every later one leans on it.

The reason is specific, not just "it's about passwords." Diffie-Hellman's original 1976 key exchange [2] has no authentication built in - it was never designed to verify who you're talking to, only to let two parties agree on a secret. For nearly fifty years, systems that needed password-based authentication either bolted authentication on top of an unauthenticated exchange (reintroducing man-in-the-middle risk) or sent the password itself over a channel secured only by TLS - meaning the server still had to receive, and therefore could still leak, the actual password. OPAQUE is the first protocol in this bibliography that closes that gap properly and provably: the server never sees the password, not even once, not even at signup, and the protocol is specifically proven secure against an attacker who steals the server's entire database and tries to guess passwords offline against it.

That property directly answers the strongest attacks documented elsewhere in this review - the credential-stuffing case study [4] and the PAKE guessing-attack analysis [5] both describe failure modes that a correctly implemented OPAQUE deployment is specifically designed to resist. It's also the paper with the clearest evidence of the theory-practice lag this whole report is about: proven secure in 2018, only standardized by the IETF in 2025, and still lacking the kind of accessible, drop-in implementations that would let an ordinary developer actually use it without becoming a cryptography expert first. If there's one paper worth reading in full from this bibliography, it's this one - not because the others don't matter, but because this is the paper where the report's whole argument stops being a survey of problems and starts being a specific, buildable answer.

Literature Survey Table

Citation	Objectives	Methodology	Key Findings	Limitations	Research Gaps
[1] Saltzer & Schroeder, 1975	Define system protection principles	Conceptual/theoretical synthesis	Least privilege, complete mediation defined	Predates networked/cloud auth	No remote password-auth coverage
[2] Diffie & Hellman, 1976	Solve key distribution; invent public-key crypto	Mathematical construction	Shared secret over open channel possible	No party authentication; MITM-prone	Auth left unsolved - closed by [13]
[3] Goldwasser, Micali & Rackoff, 1985	Formally define zero-knowledge proofs	Complexity-theoretic proof	ZK proofs exist for non-trivial cases	Purely theoretical, no implementation	Efficient deployable ZK auth unaddressed for decades
[4] 23andMe Breach, 2025	Analyse real credential-stuffing breach	Forensic case study	Password reuse enabled access, no direct breach	Single case study	Little focus on protocol-level fixes
[5] Reverse Guessing on PAKE, 2026	Analyse guessing attacks on PAKE protocols	Formal attack modelling	Guessing can beat naive brute force	May be protocol-specific	Needs more protocol-specific hardening
[6] Phishing Survey, 2023	Build cross-medium phishing taxonomy	Systematic literature survey	No single defence covers all mediums	Survey-based, no experiments	Unified cross-medium defence lacking
[7] ITU-T X.800, 1991	Define OSI security architecture/vocabulary	Standards specification	Defines authentication, integrity, non-repudiation	Predates modern web/IoT contexts	No password/ZK-specific mechanisms
[8] Rivest, Shamir & Adleman, 1978	Build practical public-key cryptosystem	Mathematical construction (factoring)	First practical public-key system	Heavier than ECC, larger keys	No password-auth-specific treatment
[9] Koblitz (ECC), 1987	Introduce elliptic-curve cryptography	Mathematical construction	Shorter keys, same RSA-level security	Historically slower adoption	No authentication-protocol design
[10] AES/DES/RSA/ECC Comparative, 2023	Compare symmetric/asymmetric performance	Experimental benchmarking	No universal winner; context-dependent	Limited real-world hardware variety	Little mobile/constrained-device testing
[11] ChaCha20 Review, 2024	Explain ChaCha20 design/security	Technical/expository review	Resists differential/linear cryptanalysis	Not peer-reviewed original research	No side-channel implementation analysis
[12] ChaCha20 Memory Analysis, 2019	Test ChaCha20 key extraction from memory	Experimental memory-forensics attack	Keys recoverable from VM memory	Requires attacker memory access	Other ciphers/platforms not covered
[13] OPAQUE, 2018	Design server-never-sees-password PAKE	Formal protocol design + proof	Resists offline/server-compromise attacks; now RFC 9807	No performance benchmarking in paper	Accessible implementations still scarce
[14] Enhanced MFA Framework, 2025	Propose adaptive real-time risk engine	System/framework design	Dynamic trust scoring grants/blocks in real time	Limited large-scale validation	False-positive rates need evaluation
[15] Sarker, Behavioural ML Auth, 2022	Survey ML-based behavioural authentication	Systematic literature survey	Behavioural signals add real auth signal	Survey-based, no independent validation	Little cross-study standardization
[16] Real-Time Risk-Based AI Access, 2025	Describe AI-driven real-time access decisions	Framework: Zero Trust + AI	Continuous per-session risk scoring proposed	Preprint, not peer-reviewed	Real deployment validation missing
[17] NIST PQC Standards Review, 2025	Review finalized post-quantum standards	Standards/implementation review	Practical PQC migration strategies exist	Long-term performance data limited	Full-system migration underdeveloped
[18] Post-Quantum Crypto Survey, 2023	Survey NIST PQC competition finalists	Comparative literature survey	Trade-offs vary by platform	No independent benchmarking	Sparse real-device deployment data
[19] AI in Cryptanalysis Survey, 2025	Survey AI applications in cryptanalysis	Systematic literature survey	Deep learning aids side-channel analysis	Not tested against PAKE specifically	No AI-vs-PAKE guessing-attack study yet
[20] IoT Cloud Security Case Study, 2021	Examine real IoT device authentication	Empirical case-study analysis	Devices used spoofable fixed MAC IDs	Small device sample	Larger-scale IoT auth audits lacking

References

- <https://ieeexplore.ieee.org/document/1451869>
- [2] Diffie, W., & Hellman, M.E. (1976). New Directions in Cryptography. IEEE Transactions on Information Theory, 22(6), 644–654.
<https://ee.stanford.edu/~hellman/publications/24.pdf>
- [3] Goldwasser, S., Micali, S., & Rackoff, C. (1985). The Knowledge Complexity of Interactive Proof-Systems. Proceedings of the 17th Annual ACM STOC, 291–304.
<https://dl.acm.org/doi/10.1145/22145.22178>
- [4] The 23andMe Data Breach: Analyzing Credential Stuffing Attacks, Security Vulnerabilities, and Mitigation Strategies. arXiv (2025).
<https://arxiv.org/pdf/2502.04303>
- [5] Reverse Online Guessing Attacks on PAKE Protocols. arXiv (2026).
<https://arxiv.org/pdf/2602.08993>
- [6] A Comprehensive Survey of Phishing: Mediums, Intended Targets, Attack and Defence Techniques and a Novel Taxonomy. International Journal of Information Security (2023).
<https://dl.acm.org/doi/10.1007/s10207-023-00768-x>
- [7] ITU-T Recommendation X.800: Security Architecture for Open Systems Interconnection. ITU (1991).
https://www.itu.int/rec/dologin_pub.asp?lang=e&id=T-REC-X.800-199103-I!!PDF-E&type=items
- [8] Rivest, R.L., Shamir, A., & Adleman, L. (1978). A Method for Obtaining Digital Signatures and Public-Key Cryptosystems. Communications of the ACM, 21(2), 120–126.
<https://dl.acm.org/doi/10.1145/359340.359342>
- [9] Koblitz, N. (1987). Elliptic Curve Cryptosystems. Mathematics of Computation, 48(177), 203–209.
<https://doi.org/10.1090/S0025-5718-1987-0866109-5>
- [10] AES, DES, RSA, and ECC (Comparative Performance and Security Analysis). JETIR (2023).
<https://www.jetir.org/papers/JETIR2301029.pdf>
- [11] ChaCha20: A Modern Stream Cipher for Enhanced Security. Technical review (2024).
<https://www.onlinehashcrack.com/guides/cryptography-algorithms/chacha20-a-modern-stream-cipher-for-enhanced-security.php>
- [12] Deriving ChaCha20 Key Streams From Targeted Memory Analysis. ScienceDirect (2019).
<https://www.sciencedirect.com/science/article/abs/pii/S2214212619300997>
- [13] Jarecki, S., Krawczyk, H., & Xu, J. (2018). OPAQUE: An Asymmetric PAKE Protocol Secure Against Pre-Computation Attacks. Eurocrypt 2018 / IACR ePrint 2018/163.
<https://eprint.iacr.org/2018/163>
- [14] Enhanced MFA Framework Against Modern Security Threats. Proceedings of the 2025 10th International Conference on Cloud Computing and Internet of Things.
<https://dl.acm.org/doi/10.1145/3785520.3785523>
- [15] Sarker, I.H. (2022). Machine Learning for Behavioral User Authentication: A Survey. ACM Computing Surveys, 54(9), 1–38.
<https://dl.acm.org/doi/10.1145/3530902>
- [16] Real-Time Risk-Based Access Decisions Using AI and Behavioral Analytics. ResearchGate preprint (2025).

https://www.researchgate.net/publication/396691118_REAL-TIME_RISK-BASED_ACCESS_DECISIONS_USING_AI_AND_BEHAVIORAL_ANALYTICS

- [17] NIST Post-Quantum Cryptography Standards: A Comprehensive Review of Theoretical Foundations and Implementations. IEEE Journals & Magazine (2025).
<https://ieeexplore.ieee.org/document/11352813/>
- [18] A Survey of Post-Quantum Cryptography: Start of a New Race. Cryptography (MDPI), 7(3), 40 (2023).
<https://www.mdpi.com/2410-387X/7/3/40>
- [19] A Survey on the Applications of Artificial Intelligence in Cryptanalysis and Cryptographic Design. Frontiers in Science and Engineering (2025).
<https://fse-journal.org/index.php/ojs/article/view/75>
- [20] IoT Cloud Security Review: A Case Study Approach Using Emerging Consumer-Oriented Applications. ACM Computing Surveys, 54(4), Article 75 (2021).
<https://dl.acm.org/doi/10.1145/3447625>